LLM-ERP System Architecture Blueprint (English) — v3.0

For IT directors / system architects / security consultants From 1 to 1000 customers — how does this system grow? Defense in depth, HA, DR, observability — fully exposed.

⚡ **v3.0 Strategic Pivot Notice**: Port matrix may still show Expo (8081) / LINE Webhook (TLS) etc. v3.0 removes mobile / LINE. Actual deployment only needs: 80/443 (Web) / 5432 (PostgreSQL) / 6379 (Redis) / 9000-9001 (MinIO).

📑 Contents

---

1. Seven-Layer Defense in Depth

```
┌──────────────────────────────────────────────────────────────┐
│ L0 · Edge (CDN / Cloudflare / DDoS / WAF / TLS Termination) │
└──────────────────────────────────────────────────────────────┘
                          ↓
┌──────────────────────────────────────────────────────────────┐
│ L1 · Reverse Proxy (nginx / Caddy)                           │
│      - HTTPS only / HSTS                                     │
│      - Rate limit (level 1 - by IP)                          │
│      - Security headers + CSP                                │
└──────────────────────────────────────────────────────────────┘
                          ↓
┌──────────────────────────────────────────────────────────────┐
│ L2 · API Gateway (FastAPI middleware stack)                  │
│      - SecurityHeaders → RequestID → Auth (JWT) → Audit      │
│      - Rate limit (level 2 - by user_id)                     │
└──────────────────────────────────────────────────────────────┘
                          ↓
┌──────────────────────────────────────────────────────────────┐
│ L3 · Application (12 Domain Services + 10 Agent + 26 Tool)   │
│      - RBAC (5 layers: Tenant→User→Role→Permission→Row)      │
│      - apply_tenant_filter (mandatory!)                      │
│      - apply_row_filter (by scope)                           │
└──────────────────────────────────────────────────────────────┘
                          ↓
┌──────────────────────────────────────────────────────────────┐
│ L4 · Domain Logic (Business Rules + EventBus)                │
│      - 16 Constraint Rules (e.g., no negative stock)         │
│      - SSE live push                                         │
│      - DecisionLog (AI interaction audit)                    │
└──────────────────────────────────────────────────────────────┘
                          ↓
┌──────────────────────────────────────────────────────────────┐
│ L5 · Data Layer (PostgreSQL + Redis cache?)                  │
│      - Connection pool (asyncpg)                             │
│      - Row-level tenant_id enforcement                       │
│      - Audit trail                                           │
└──────────────────────────────────────────────────────────────┘
                          ↓
┌──────────────────────────────────────────────────────────────┐
│ L6 · MESH Multi-Factory (WireGuard VPN)                      │
│      - HQ ⇔ N Factory Nodes                                  │
│      - Data stays at each site (aggregates only)             │
└──────────────────────────────────────────────────────────────┘
```

Every layer assumes "if the layer above fails, this one still holds".

2. Port Matrix

Public-facing

Port	Service	Exposure	Notes
443	HTTPS Web	Public	Cloudflare in front
80	HTTP redirect → 443	Public	No plaintext allowed
— (none)	LINE Bot Webhook	Cloudflare Tunnel	No fixed port

Internal LAN (office only)

Port	Service	Exposure	Notes
8000	FastAPI backend	Internal	Only via nginx
5173	Desktop UI (nginx)	Internal	Dev / internal use
5432	PostgreSQL	data network only	**Never public**

MESH (Multi-factory)

Port	Service	Exposure	Notes
8001-8009	Factory Nodes	WireGuard VPN	Per factory
51820	WireGuard VPN	Public UDP	Encrypted tunnel

Observability (internal)

Port	Service	Notes
9090	Prometheus	scrape /metrics
3000	Grafana	dashboards
9200	Elasticsearch (logs)	optional

3. Firewall Rule Templates

iptables / ufw (Ubuntu Server)

```
# Default deny all
ufw default deny incoming
ufw default allow outgoing

# Public: only 80/443
ufw allow 443/tcp comment "HTTPS"
ufw allow 80/tcp comment "HTTP→HTTPS redirect"

# Office whitelist: SSH / dev ports
ufw allow from 192.168.0.0/24 to any port 22 comment "SSH from office"
ufw allow from 192.168.0.0/24 to any port 5173 comment "Desktop UI"
ufw allow from 192.168.0.0/24 to any port 8000 comment "Backend dev"

# MESH WireGuard
ufw allow 51820/udp comment "WireGuard"

# DB **never** opens to public
# Port 5432 omitted = default deny

ufw enable
```

Cloud Security Group (AWS / GCP)

Source	Port	Protocol	Purpose
0.0.0.0/0	443	TCP	HTTPS
0.0.0.0/0	80	TCP	redirect
0.0.0.0/0	51820	UDP	WireGuard
Office IP CIDR	22	TCP	SSH
Office IP CIDR	5173, 8000	TCP	Dev access
Not open	5432	—	DB (via VPC peering only)

4. TLS / PKI Architecture

4.1 Public Cert

```
[Let's Encrypt / Cloudflare]
        ↓ 90-day auto-renew
[nginx (TLS termination)]
        ↓ HTTP internal
[backend / frontend]
```

Auto-renew:

```
0 3 * * * certbot renew --quiet --post-hook "nginx -s reload"
```

4.2 Internal mTLS (Advanced)

For high-security customers, HQ ↔ Factory Node should use mTLS:

```
[Internal CA (step-ca or cert-manager)]
        ↓ signs client + server certs
[HQ Backend] ⟵ mTLS ⟶ [Factory Node]
```

Implementation: `httpx.AsyncClient(verify="/path/ca.pem", cert=("client.crt","client.key"))`.

4.3 TLS Versions and Ciphers

```
ssl_protocols TLSv1.2 TLSv1.3;
ssl_ciphers HIGH:!aNULL:!MD5:!RC4:!DSS;
ssl_prefer_server_ciphers on;
```

Disable: TLS 1.0/1.1, RC4, 3DES, SHA1 signatures.

---

5. Secrets Management

5.1 Three Storage Tiers

Tier	Method	For
Dev	`.env` (gitignored)	Local / Demo
Small customer	`.env` + file permission 600 + LUKS-encrypted disk	50-100 person factory
Enterprise	HashiCorp Vault / AWS Secrets Manager	Multi-factory / Listed

5.2 Must-Rotate Secrets

Secret	Rotation	Tool
`JWT_SECRET`	90 days	See SECRETS_ROTATION_SOP
`POSTGRES_PASSWORD`	Half-year	ALTER ROLE PASSWORD
`LLM_API_KEY`	Yearly	Provider console
TLS cert	90 days	Let's Encrypt auto
WireGuard pubkey	Yearly	Regenerate + sync
LINE Channel secret	On change	LINE Developer Console

5.3 Detection

- Startup: `main.py` detects `JWT_SECRET=change-me` → immediately log.error
- CI: GitGuardian / TruffleHog scans commits for accidentally pushed secrets
- Runtime: `docker compose exec backend env | grep -i secret` missing expected secret → warn

---

6. HA Blueprint

6.1 Evolution Path (1 → 1000 customers)

```
Stage 1: Single Docker (1-10 customers)
  ┌────────────┐
  │ All-in-One │
  │ Docker     │
  │ SQLite     │
  └────────────┘
  SPOF: disk, machine
  RTO: 2 hours
  Cost: ~NT$ 500/month (VPS)

Stage 2: Dual machine Active-Passive (10-100 customers)
  ┌────────────┐   ┌────────────┐
  │ Primary    │←→ │ Standby    │
  │ PostgreSQL │   │ PostgreSQL │
  │ Streaming  │   │ Replication│
  └────────────┘   └────────────┘
  Auto-failover
  RTO: 5 minutes
  Cost: ~NT$ 5,000/month (2 cloud VMs)

Stage 3: Load-balanced (100-500 customers)
  ┌──────────┐
  │ Load     │
  │ Balancer │
  └──────────┘
       ↓
  ┌────┐ ┌────┐ ┌────┐
  │ B1 │ │ B2 │ │ B3 │  Backend ×3
  └────┘ └────┘ └────┘
       ↓
  ┌──────────┐ ┌──────────┐
  │ PG Master│ │ PG Replica│
  └──────────┘ └──────────┘
  Read replica for analytics
  Redis cache
  RTO: < 1 minute
  Cost: ~NT$ 30,000/month

Stage 4: Kubernetes / Multi-region (500+ customers)
  Multi-region deployment
  PostgreSQL HA cluster (Patroni)
  Auto-scaling
  CDN
  RTO: seconds
  Cost: ~5% of revenue per customer
```

6.2 When to Upgrade?

Signal	Upgrade To
AI latency > 10s	+ Redis cache
5+ concurrent users	Add backend replica
DB CPU > 80%	+ read replica
Cross-region customers	Multi-region
> 100 concurrent	Kubernetes

---

7. DR with RPO/RTO

7.1 RPO/RTO Targets

Tier	RPO	RTO	For
Basic	24 hours	2 hours	50-person factory standard
Pro	1 hour	30 minutes	+ WAL streaming
Enterprise	5 minutes	5 minutes	+ multi-region failover

See `BACKUP_RESTORE_SOP_EN.md`.

7.2 4 DR Scenario Drills

Conduct quarterly:

Scenario	Drill Script	Target RTO
Disk failure	Replace disk + restore daily	2 hours
Data center fire	S3 weekly + new cloud VM	8 hours
Ransomware	Isolate + restore + security review	1 hour
Accidental deletion	Restore + RBAC tighten	30 minutes

---

8. Multi-tenant Isolation 4-Layer Defense

```
[Layer 1] tenant_id column (all 19 business tables)
          └ Physical column exists; non-optional
                ↓
[Layer 2] Auto-injection (install_tenant_auto_injection)
          └ Session auto-fills tenant_id from contextvar on create
                ↓
[Layer 3] apply_tenant_filter (every list/get/search endpoint)
          └ WHERE tenant_id = ctx.tenant_id enforced
          └ ★ Even is_superuser=True cannot cross tenants
          └ Only exception: explicit 'tenant.cross' permission
                ↓
[Layer 4] Integration tests verify (tests/integration/test_tenant_isolation.py)
          └ 4 cases: create / read / reverse / ID-guessing attack
          └ run_gates.sh runs every time — any fail → red light
```

This is the SaaS lifeline. One layer broken = legal lawsuit + brand destroyed.

---

9. Observability

9.1 Logging (Implemented)

- Structured JSON (production `LOG_JSON=true`)
- Every line carries `request_id` for correlation
- Written to `/var/log/llm-erp/`
- Aggregation: Loki / ELK / CloudWatch Logs

9.2 Metrics (Planned)

- Prometheus endpoint `/metrics` (Phase 2)
- Key metrics:
  - HTTP request rate / latency / error rate
  - DB connection pool usage
  - LLM call count / tokens / cost
  - SSE connection count

9.3 Tracing (Planned)

- OpenTelemetry SDK
- Jaeger / Tempo backend
- Cross-service trace: HQ → Factory Node → DB

9.4 SLO Targets

SLI	SLO	Error Budget
Availability (status=ok)	99.9%	43 min/month
Health API < 200ms	95%	5%
Inventory query < 1s	99%	1%
AI chat < 10s	90%	10% (LLM-dependent)

10. Cost-of-Ownership

Customers	Cloud/month	LLM API	People	Total/month
1-10 (single)	NT$ 500	NT$ 1,000	0.1 FTE	~NT$ 10,000
10-100 (dual)	NT$ 5,000	NT$ 10,000	0.5 FTE	~NT$ 50,000
100-500 (LB)	NT$ 30,000	NT$ 50,000	2 FTE	~NT$ 280,000
500-1000 (K8s)	NT$ 100,000	NT$ 200,000	5 FTE	~NT$ 800,000

Avg cost per customer/month: ~NT$ 800-1,000 (incl. people) → at NT$ 5,000/month ARPU, 80% gross margin.

📎 Related Documents

- System Topology
- Network Deployment
- Backup & Restore SOP
- Support Runbook
- Secrets Rotation SOP
- **Chinese version**: `ARCHITECTURE_BLUEPRINT_ZH.md`

Version: 2.6 · **Last updated**: 2026-05-14